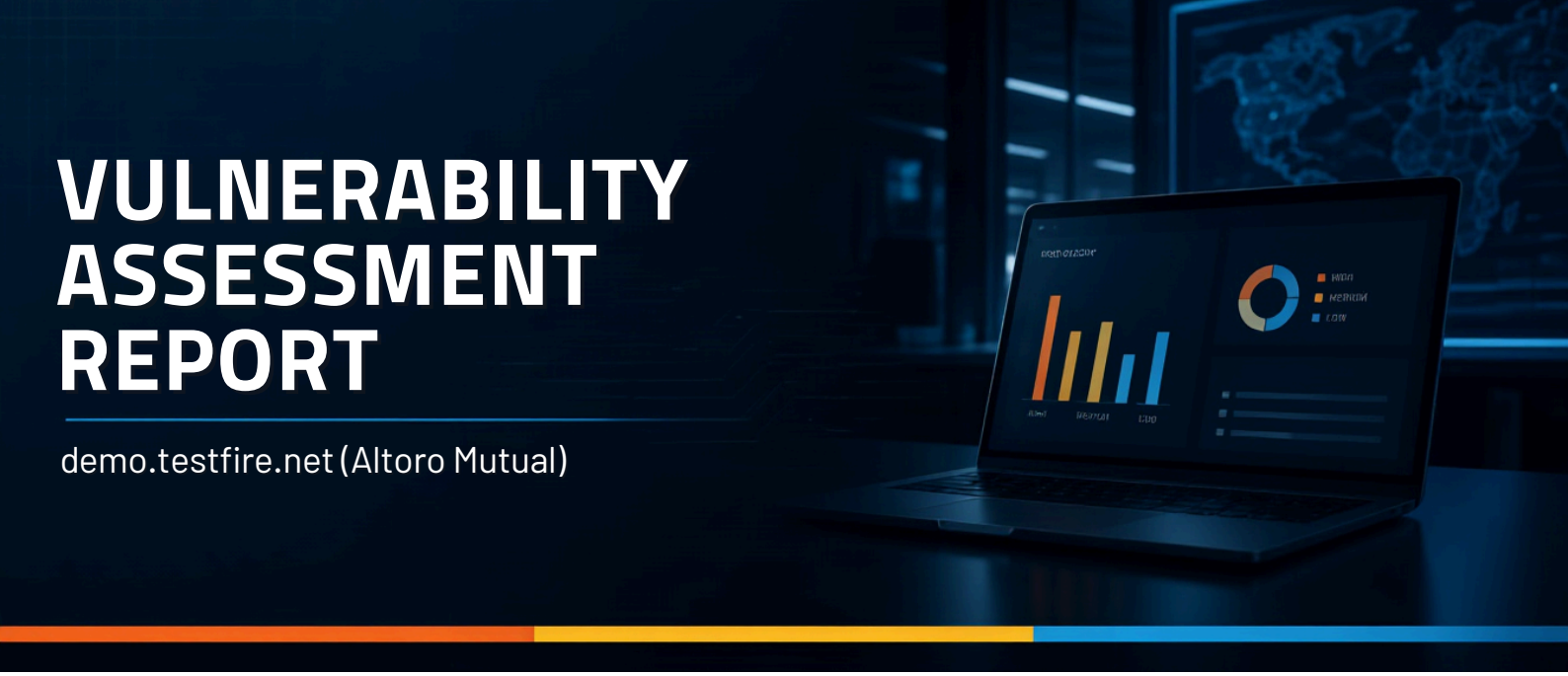
VULNERABILITY ASSESSMENT REPORT

demo.testfire.net (Altoro Mutual)



demo.testfire.net (Altoro Mutual)

Prepared by	Patricia Wanjiru Wachira
Date	13 October 2026
Target	demo.testfire.net (65.61.137.117)
Type	Reconnaissance and configuration review

Medium	Low	Informational

Contents and document information

1. Executive summary
2. Scope and methodology
3. Attack surface
4. Findings overview
5. Detailed findings (F1-F12)
6. Positive observations
7. Remediation roadmap
8. Limitations and next steps
9. Appendices

Document information

Version	1.0
Testing window	1-13 October 2026
Tools	Nmap 7.991, curl, OWASP ZAP, online security-headers scanner, Firefox developer tools
Authorization	the target is a public, intentionally vulnerable demo application intended for security testing practice.

1 Executive summary

This assessment examined the externally visible configuration of demo.testfire.net, a public banking demo application (Altoro Mutual), on 12-13 October 2026. Testing covered port and service scanning, TLS analysis, HTTP header and cookie review, and passive web-application analysis. No exploitation or authenticated testing was performed. Twelve findings were identified: 7 Medium, 4 Low and 1 Informational. No High-severity issues were found within this scope.

Most significant issues

The TLS certificate expired on 21 June 2026 so certificate-validating clients refuse the connection; the application is served over plaintext HTTP with no redirect to HTTPS; the session cookie lacks the Secure flag on the HTTP ports; deprecated TLS 1.0/1.1 and weak 1024-bit Diffie-Hellman parameters are enabled; browser protections are missing (Content-Security-Policy and anti-clickjacking headers). Together these mean users cannot reliably establish a secure connection and the application lacks browser-side defenses. Almost all issues are configuration changes that can be fixed quickly.

Finding severity distribution

Severity	Count
High	0
Medium	7
Low	4
Informational	1

2 Scope and methodology

Scope

In scope: demo.testfire.net (65.61.137.117), TCP ports 80, 443 and 8080, and the web application as seen without logging in. Out of scope: exploitation, authenticated testing, input-validation testing (SQL injection, XSS), UDP and full port-range scanning.

Methodology

Step	Activity	Tools
1	Port and service discovery (top 100 TCP ports)	Nmap
2	HTTP header and cookie review	Nmap scripts and curl
3	TLS certificate and cipher analysis	Nmap ssl-cert and ssl-enum-ciphers
4	Passive web-application analysis	OWASP ZAP, security-headers scanner and Firefox console
5	Analysis, correlation across tools and severity rating	manual

Severity key

Severity	Definition
High	directly exploitable with major impact
Medium	weakens a core protection or enables an attack under common conditions
Low	hardening gap or information disclosure
Informational	no direct risk

3 Attack surface

Only 3 of the top 100 TCP ports are open. The other 97 are filtered, so a firewall silently drops packets, which keeps the exposed surface small.

Port	State	Service	Detection
80/tcp	open	http	Apache Tomcat/Coyote JSP engine 1.1
443/tcp	open	https	Apache Tomcat/Coyote JSP engine 1.1
8080/tcp	open	http	Apache Tomcat/Coyote JSP engine 1.1

All three ports serve the same application (Altoro Mutual). Nmap labels 8080 http-proxy from the port number only; there is no evidence it is a proxy.

```
training-shell> nmap -sV -Pn --top-ports 100 demo.testfire.net -oN evide
nce/nmap/01_service_scan.txt
Starting Nmap 7.991 ( https://nmap.org ) at 2026-10-12 06:49 -0400
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.25s latency).
Not shown: 97 filtered tcp ports (no-response)
PORT     STATE SERVICE  VERSION
80/tcp   open  http     Apache Tomcat/Coyote JSP engine 1.1
443/tcp  open  ssl/http Apache Tomcat/Coyote JSP engine 1.1
8080/tcp open  http     Apache Tomcat/Coyote JSP engine 1.1

Service detection performed. Please report any incorrect results at http
s://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.14 seconds
```

Figure 1: Nmap service scan showing ports 80, 443 and 8080 open.

4 Findings overview

The findings below consolidate the identified cybersecurity issues, their severity, and the affected services or application areas.

ID	Finding	Severity	Affected
F1	Expired TLS certificate	Medium	443
F2	Deprecated TLS 1.0/1.1 enabled	Medium	443
F3	Weak 1024-bit Diffie-Hellman parameters	Medium	443
F4	Plaintext HTTP with no HTTPS redirect	Medium	80 (8080 untested)
F5	Session cookie lacks Secure flag	Medium	80 and 8080
F6	Session cookie lacks SameSite	Low	all ports
F7	Missing Content-Security-Policy	Medium	web app
F8	Missing anti-clickjacking protection	Medium	web app
F9	Missing X-Content-Type-Options	Low	web app
F10	Missing Referrer-Policy and Permissions-Policy	Low	web app
F11	Server/technology version disclosure	Low	ports 80/443/8080
F12	Informational items	Informational	various

Medium | Low | Informational

5.1 F1 Expired TLS certificate

MEDIUM

Severity

Affected asset

443/tcp

Description

The certificate for demo.testfire.net (Sectigo DV, RSA 2048-bit, SHA-256) was valid from 21 May 2025 to 21 June 2026; at testing it had been expired for about 114 days.

Evidence

Nmap ssl-cert shows Not valid after 2026-06-21, repeated on two scan days; curl -I https://demo.testfire.net fails with certificate has expired (10).

Impact

Browsers show a warning and certificate-validating clients refuse the connection; users learn to click through warnings, which makes man-in-the-middle attacks harder to notice.

Recommendation

Install a valid certificate and automate renewal with expiry monitoring and alerts.

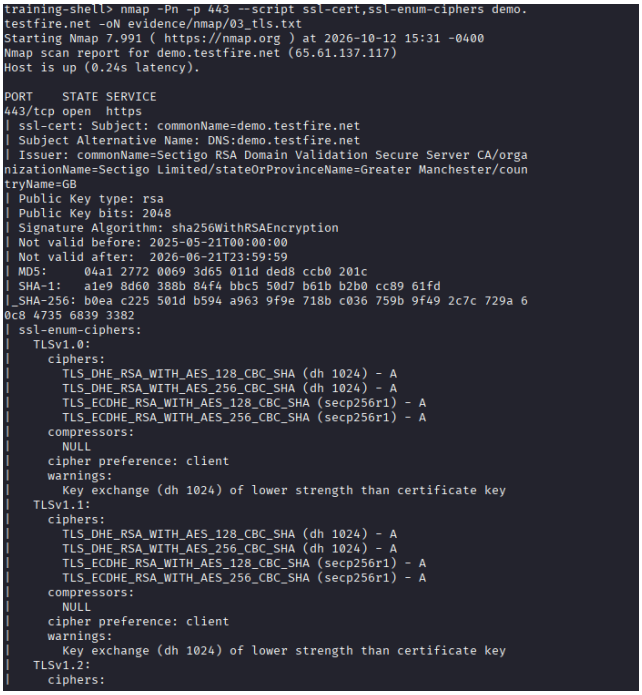


Figure 2: Certificate validity dates from Nmap ssl-cert.

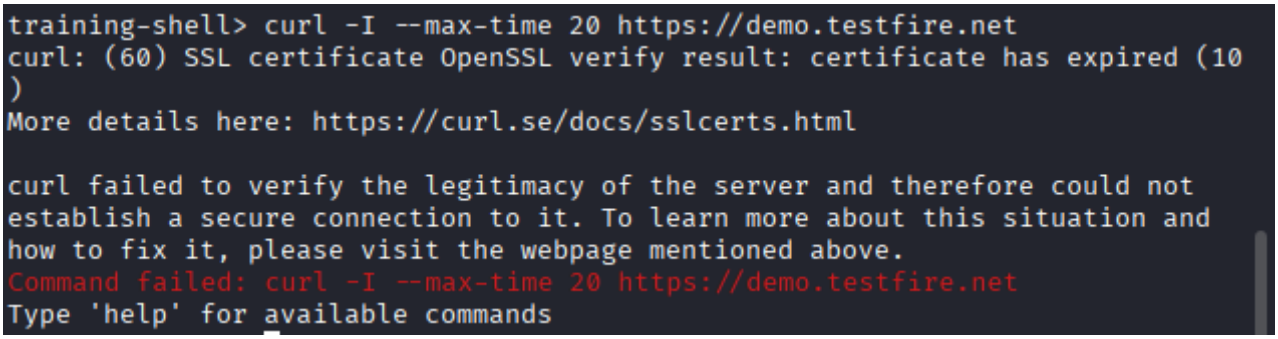


Figure 3: curl rejects the certificate as expired.

5.2 F2 Deprecated TLS 1.0 and 1.1 enabled / 5.3 F3 Weak 1024-bit Diffie-Hellman parameters

5.2 F2 — Deprecated TLS 1.0 and 1.1 enabled

Medium

Description and evidence

The server accepts TLS 1.0 and 1.1 (deprecated by RFC 8996); TLS 1.3 was not listed.

Impact

Fails common compliance baselines such as PCI DSS and keeps legacy CBC-only suites available; this is a risk class and no attack was attempted.

Recommendation

Disable TLS 1.0/1.1, keep TLS 1.2 and enable TLS 1.3.

5.3 F3 — Weak 1024-bit Diffie-Hellman parameters

Medium

Description and evidence

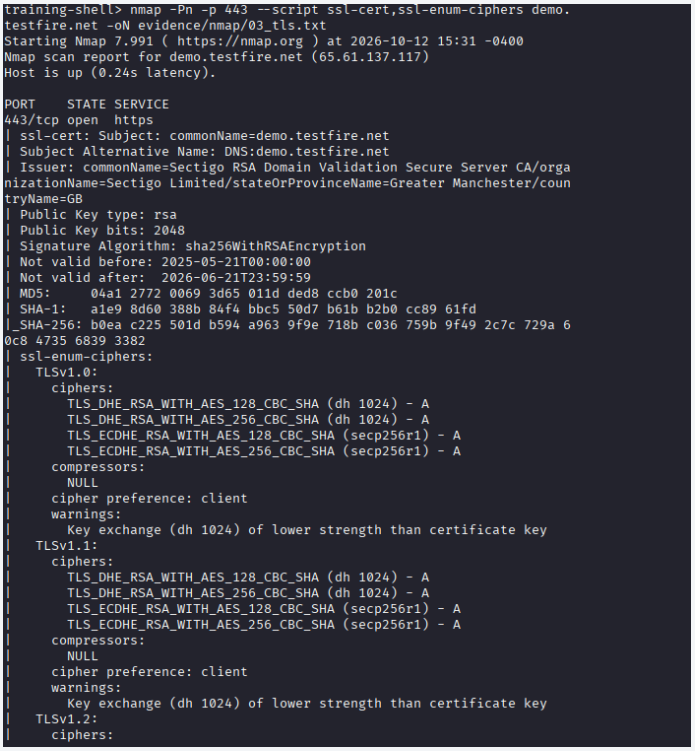
All DHE suites use 1024-bit parameters which Nmap flags as weaker than the 2048-bit certificate key.

Impact

This is the weak-DH class of issue associated with Logjam (CVE-2015-4000); susceptibility was not tested directly.

Recommendation

Use DH parameters of 2048 bits or more, or remove DHE suites and rely on ECDHE.



```
training-shell> nmap -Pn -p 443 --script ssl-cert,ssl-enum-ciphers demo.
testfire.net -oN evidence/nmap/03_tls.txt
Starting Nmap 7.991 ( https://nmap.org ) at 2026-10-12 15:31 -0400
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.24s latency).

PORT    STATE SERVICE
443/tcp open  https
| ssl-cert: Subject: commonName=demo.testfire.net
| Subject Alternative Name: DNS:demo.testfire.net
| Issuer: commonName=Sectigo RSA Domain Validation Secure Server CA/orga
nizationName=Sectigo Limited/stateOrProvinceName=Greater Manchester/coun
tryName=GB
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2025-05-21T00:00:00
| Not valid after:  2026-06-21T23:59:59
| MD5:     04a1 2772 0069 3d65 011d ded8 ccb0 201c
| SHA-1:   a1e9 8d60 388b 84f4 bbc5 50d7 b61b b2b0 cc89 61fd
|_SHA-256: b0ea c225 501d b594 a963 9f9e 718b c036 759b 9f49 2c7c 729a 6
0c8 4735 6839 3382
| ssl-enum-ciphers:
|   TLSv1.0:
|     ciphers:
|       TLS_DHE_RSA_WITH_AES_128_CBC_SHA (dh 1024) - A
|       TLS_DHE_RSA_WITH_AES_256_CBC_SHA (dh 1024) - A
|       TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (secp256r1) - A
|     compressors:
|       NULL
|     cipher preference: client
|     warnings:
|       Key exchange (dh 1024) of lower strength than certificate key
|   TLSv1.1:
|     ciphers:
|       TLS_DHE_RSA_WITH_AES_128_CBC_SHA (dh 1024) - A
|       TLS_DHE_RSA_WITH_AES_256_CBC_SHA (dh 1024) - A
|       TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (secp256r1) - A
|     compressors:
|       NULL
|     cipher preference: client
|     warnings:
|       Key exchange (dh 1024) of lower strength than certificate key
|   TLSv1.2:
|     ciphers:
```

Figure 4: Deprecated protocols and 1024-bit DH parameters in Nmap output.

Note

Nmap's least strength A summary grades each cipher alone and ignores the deprecated protocols, 1024-bit DH and the expired certificate, so it is not a clean result.

5.4 F4 Plaintext HTTP / 5.5 F5 Session cookie / 5.6 F6 SameSite

5.4 F4 Plaintext HTTP Medium

Finding

http://demo.testfire.net returns 200 OK directly with no redirect and no Strict-Transport-Security header; port 8080 is also open (not re-tested with curl).

Impact

Traffic including session cookies and credentials can be read or altered on the network path; combined with F1 there is no reliably secure way to reach the site.

Recommendation

Redirect all HTTP to HTTPS (301), add HSTS once the certificate is valid, close 8080 if unused.

5.5 F5 Session cookie Medium

Finding

JSESSIONID is issued over HTTP with HttpOnly only; on 443 the cookie does carry Secure.

Impact

The cookie can travel in cleartext and be intercepted, enabling session hijacking.

Recommendation

Set Secure, HttpOnly and SameSite on session cookies and serve the app over HTTPS only.

5.6 F6 SameSite Low

Finding

No SameSite attribute on any port, also flagged by ZAP.

Impact

Weaker protection against cross-site request forgery.

Recommendation

Set SameSite=Lax or Strict and add anti-CSRF tokens.

```
training-shell> curl -sI http://demo.testfire.net | tee evidence/headers/http
_headers.txt
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=142A87723F2E6E47F5A62A1FA7E2F3E9; Path=/; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Transfer-Encoding: chunked
Date: Tue, 13 Oct 2026 06:27:51 GMT
```

Figure 5: Session cookie with HttpOnly only (curl).

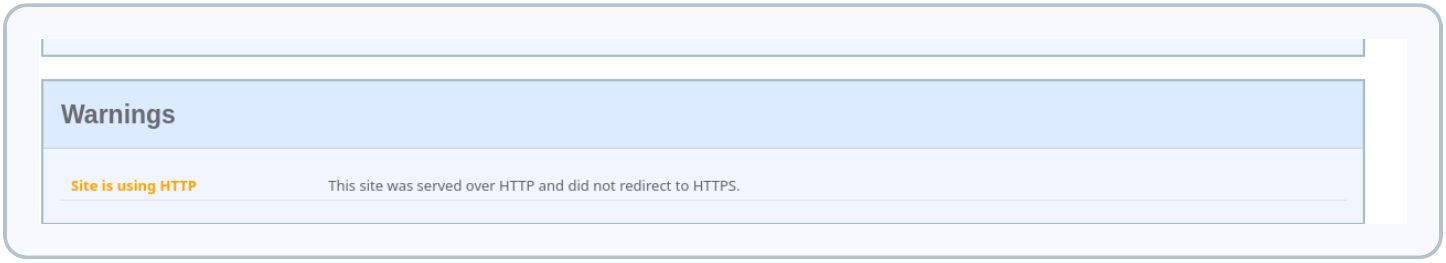


Figure 6: No redirect from HTTP to HTTPS (security-headers scan warning).

5.7–5.10 Browser security headers

ID	Header	Severity	Purpose
F7	Content-Security-Policy	Medium	prevents cross-site scripting and content injection
F8	X-Frame-Options / frame-ancestors	Medium	prevents clickjacking
F9	X-Content-Type-Options	Low	prevents MIME sniffing
F10	Referrer-Policy and Permissions-Policy	Low	prevents URL leakage and unrestricted browser features

Recommendations

F7: Deploy a CSP starting in report-only mode then enforce. F8: Send X-Frame-Options SAMEORIGIN or CSP frame-ancestors 'self'. F9: Add X-Content-Type-Options nosniff. F10: Add Referrer-Policy strict-origin-when-cross-origin and a restrictive Permissions-Policy.

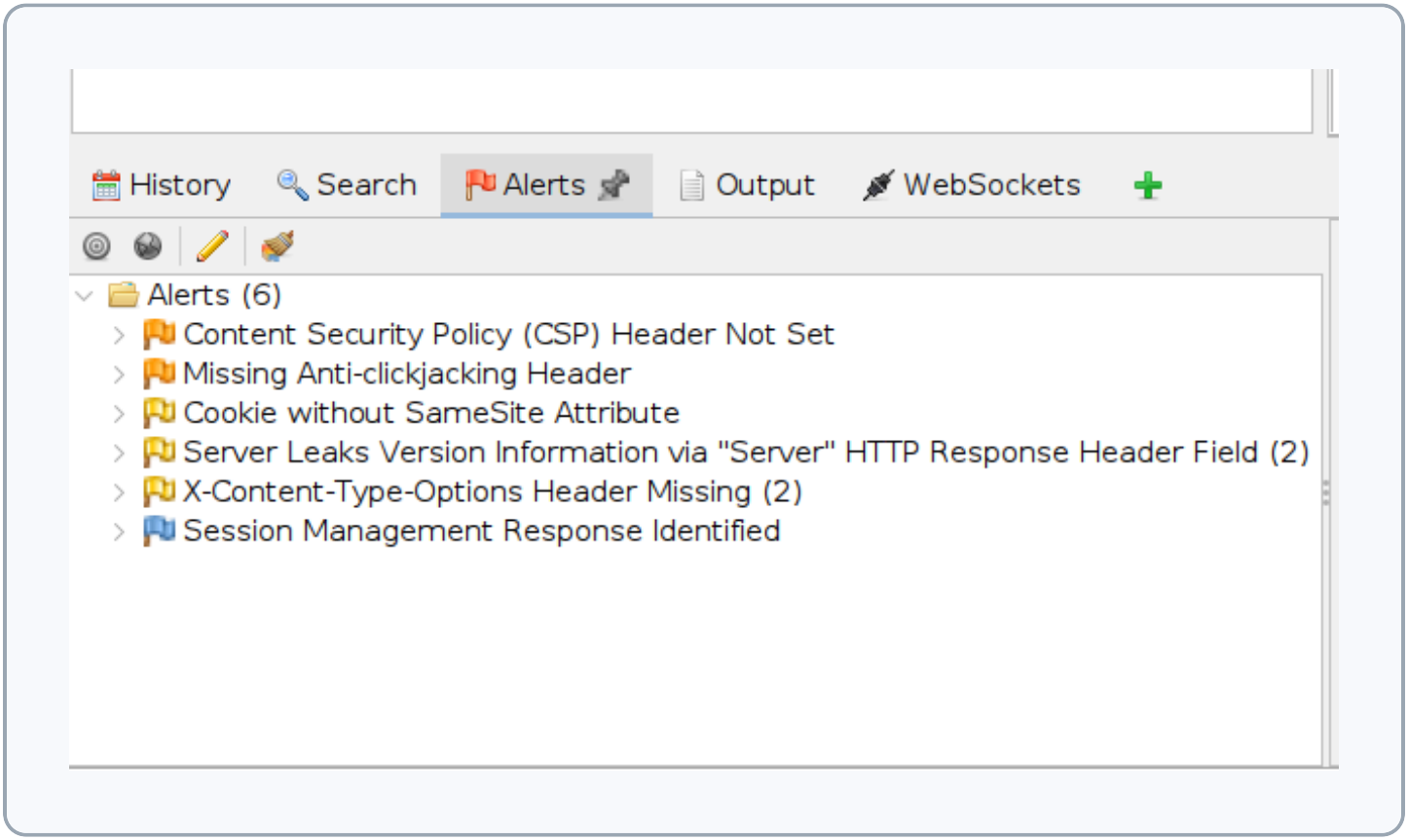


Figure 7: OWASP ZAP alerts for the target.

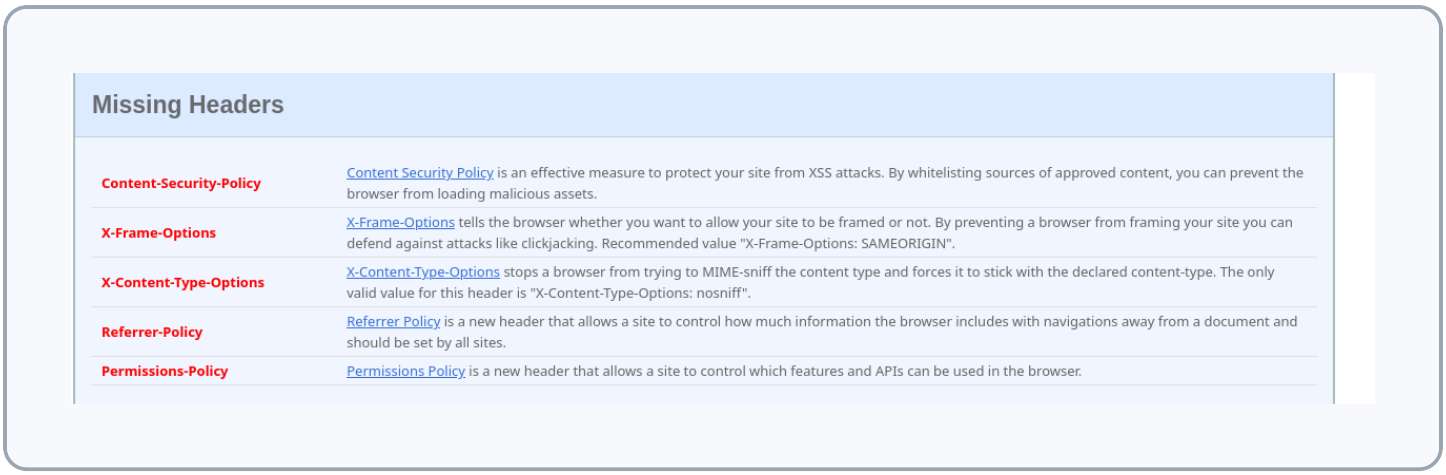


Figure 8: Missing security headers reported by the headers scan.